

GTOS Detailed Volume - Volume 05

Identity Tenant Organization

GTOS Enterprise Engineering Handbook - Final Edition 1.0

Source Chapters

- Identity and Tenant Architecture Introduction
- Human Identity and Person Profile
- Organization and Legal-Entity Identity
- Service and Workload Identity
- Device, Browser, and Mobile Identity
- AI Agent and Agent-Run Identity
- Account, Credential, and Recovery Lifecycle
- Authentication, OAuth2, OIDC, JWT, and Keycloak
- Multi-Factor and Step-Up Authentication
- Session, Refresh, Revocation, and Logout
- Tenant, Company, Workspace, Facility, and Channel Scope
- Membership, Employment, and Participant Relationships
- Role, Permission, ABAC, and ReBAC
- Delegation, Mandate, Power of Attorney, and Representation
- Impersonation, Support Access, and Emergency Access
- Identity Proofing, KYB, KYC, and Qualification
- Consent, Purpose, Privacy, and Data Subject Rights
- Cross-Tenant Isolation and Confused-Deputy Prevention
- Identity Audit, Non-Repudiation, and Historical Reconstruction
- Identity Migration and Legacy Compatibility
- Identity and Tenant Conformance Matrix

Identity and Tenant Architecture

Introduction

Metadata	Value
Volume	5
Chapter ID	V05-00
Subject	IdentityArchitecture
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define identity, authority, tenancy, relationships, credentials, sessions, delegation, audit, and cross-tenant conformance.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IdentityArchitecture	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityArchitectureVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityArchitectureDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityArchitectureEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityArchitectureException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IdentityArchitecture {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIdentityArchitecture
- ValidateIdentityArchitecture
- ApproveIdentityArchitecture
- ActivateIdentityArchitecture
- SuspendIdentityArchitecture
- CorrectIdentityArchitecture
- RetireIdentityArchitecture

Reference Events:

- IdentityArchitectureCreated
- IdentityArchitectureValidated
- IdentityArchitectureApproved
- IdentityArchitectureActivated
- IdentityArchitectureSuspended
- IdentityArchitectureCorrected
- IdentityArchitectureRetired

Reference queries:

- GetIdentityArchitecture
- ListIdentityArchitectureRecords
- GetIdentityArchitectureTimeline
- GetIdentityArchitectureEvidence
- GetIdentityArchitectureDecisionPackage
- GetIdentityArchitectureExceptions
- GetIdentityArchitectureAuditTrail

Reference API surface:

```

POST /api/v1/identityarchitecture/commands
GET  /api/v1/identityarchitecture/{id}
GET  /api/v1/identityarchitecture/{id}/timeline
GET  /api/v1/identityarchitecture/{id}/evidence
GET  /api/v1/identityarchitecture/{id}/decisions
POST /api/v1/identityarchitecture/{id}/exceptions
POST /api/v1/identityarchitecture/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
identityarchitecture_aggregate	authoritative subject
identityarchitecture_version	immutable submitted, approved, issued, or signed versions
identityarchitecture_relationship	governed relationships
identityarchitecture_decision	binding Decisions and rationale
identityarchitecture_evidence_link	provenance and evidence relationships
identityarchitecture_event_outbox	transactional Event publication
identityarchitecture_idempotency	duplicate-write protection
identityarchitecture_exception	exception, claim, dispute, or hold
identityarchitecture_correction	correction and supersession lineage
identityarchitecture_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Human Identity and Person Profile

Metadata	Value
Volume	5
Chapter ID	V05-01
Subject	HumanIdentity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity Domain
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **represent a natural person independently from accounts, roles, memberships, credentials, and employment.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity Domain**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
HumanIdentity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
HumanIdentityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
HumanIdentityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
HumanIdentityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
HumanIdentityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
HumanIdentity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateHumanIdentity
- ValidateHumanIdentity
- ApproveHumanIdentity
- ActivateHumanIdentity
- SuspendHumanIdentity
- CorrectHumanIdentity
- RetireHumanIdentity

Reference Events:

- HumanIdentityCreated
- HumanIdentityValidated
- HumanIdentityApproved
- HumanIdentityActivated
- HumanIdentitySuspended
- HumanIdentityCorrected
- HumanIdentityRetired

Reference queries:

- GetHumanIdentity
- ListHumanIdentityRecords
- GetHumanIdentityTimeline
- GetHumanIdentityEvidence
- GetHumanIdentityDecisionPackage
- GetHumanIdentityExceptions
- GetHumanIdentityAuditTrail

Reference API surface:

```

POST /api/v1/humanidentity/commands
GET  /api/v1/humanidentity/{id}
GET  /api/v1/humanidentity/{id}/timeline
GET  /api/v1/humanidentity/{id}/evidence
GET  /api/v1/humanidentity/{id}/decisions
POST /api/v1/humanidentity/{id}/exceptions
POST /api/v1/humanidentity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
humanidentity_aggregate	authoritative subject
humanidentity_version	immutable submitted, approved, issued, or signed versions
humanidentity_relationship	governed relationships
humanidentity_decision	binding Decisions and rationale
humanidentity_evidence_link	provenance and evidence relationships
humanidentity_event_outbox	transactional Event publication
humanidentity_idempotency	duplicate-write protection
humanidentity_exception	exception, claim, dispute, or hold
humanidentity_correction	correction and supersession lineage
humanidentity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Organization and Legal-Entity Identity

Metadata	Value
Volume	5
Chapter ID	V05-02
Subject	OrganizationIdentity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity / Customer / Provider
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **represent companies, legal entities, branches, trade names, registrations, jurisdictions, and organizational relationships**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity / Customer / Provider**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
OrganizationIdentity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
OrganizationIdentityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
OrganizationIdentityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
OrganizationIdentityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
OrganizationIdentityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
OrganizationIdentity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateOrganizationIdentity
- ValidateOrganizationIdentity
- ApproveOrganizationIdentity
- ActivateOrganizationIdentity
- SuspendOrganizationIdentity
- CorrectOrganizationIdentity
- RetireOrganizationIdentity

Reference Events:

- OrganizationIdentityCreated
- OrganizationIdentityValidated
- OrganizationIdentityApproved
- OrganizationIdentityActivated
- OrganizationIdentitySuspended
- OrganizationIdentityCorrected
- OrganizationIdentityRetired

Reference queries:

- GetOrganizationIdentity
- ListOrganizationIdentityRecords
- GetOrganizationIdentityTimeline
- GetOrganizationIdentityEvidence
- GetOrganizationIdentityDecisionPackage
- GetOrganizationIdentityExceptions
- GetOrganizationIdentityAuditTrail

Reference API surface:

```

POST /api/v1/organizationidentity/commands
GET  /api/v1/organizationidentity/{id}
GET  /api/v1/organizationidentity/{id}/timeline
GET  /api/v1/organizationidentity/{id}/evidence
GET  /api/v1/organizationidentity/{id}/decisions
POST /api/v1/organizationidentity/{id}/exceptions
POST /api/v1/organizationidentity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C[Policy and evidence gates pass?]
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
organizationidentity_aggregate	authoritative subject
organizationidentity_version	immutable submitted, approved, issued, or signed versions
organizationidentity_relationship	governed relationships
organizationidentity_decision	binding Decisions and rationale
organizationidentity_evidence_link	provenance and evidence relationships
organizationidentity_event_outbox	transactional Event publication
organizationidentity_idempotency	duplicate-write protection
organizationidentity_exception	exception, claim, dispute, or hold
organizationidentity_correction	correction and supersession lineage
organizationidentity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Service and Workload Identity

Metadata	Value
Volume	5
Chapter ID	V05-03
Subject	ServiceIdentity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Platform
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **authenticate deployable services, jobs, gateways, adapters, and workloads with rotation and least privilege**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Platform**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
ServiceIdentity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ServiceIdentityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ServiceIdentityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ServiceIdentityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ServiceIdentityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
ServiceIdentity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateServiceIdentity
- ValidateServiceIdentity
- ApproveServiceIdentity
- ActivateServiceIdentity
- SuspendServiceIdentity
- CorrectServiceIdentity
- RetireServiceIdentity

Reference Events:

- ServiceIdentityCreated
- ServiceIdentityValidated
- ServiceIdentityApproved
- ServiceIdentityActivated
- ServiceIdentitySuspended
- ServiceIdentityCorrected
- ServiceIdentityRetired

Reference queries:

- GetServiceIdentity
- ListServiceIdentityRecords
- GetServiceIdentityTimeline
- GetServiceIdentityEvidence
- GetServiceIdentityDecisionPackage
- GetServiceIdentityExceptions
- GetServiceIdentityAuditTrail

Reference API surface:

```

POST /api/v1/serviceidentity/commands
GET  /api/v1/serviceidentity/{id}
GET  /api/v1/serviceidentity/{id}/timeline
GET  /api/v1/serviceidentity/{id}/evidence
GET  /api/v1/serviceidentity/{id}/decisions
POST /api/v1/serviceidentity/{id}/exceptions
POST /api/v1/serviceidentity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
serviceidentity_aggregate	authoritative subject
serviceidentity_version	immutable submitted, approved, issued, or signed versions
serviceidentity_relationship	governed relationships
serviceidentity_decision	binding Decisions and rationale
serviceidentity_evidence_link	provenance and evidence relationships
serviceidentity_event_outbox	transactional Event publication
serviceidentity_idempotency	duplicate-write protection
serviceidentity_exception	exception, claim, dispute, or hold
serviceidentity_correction	correction and supersession lineage
serviceidentity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Device, Browser, and Mobile Identity

Metadata	Value
Volume	5
Chapter ID	V05-04
Subject	DeviceIdentity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Platform
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **identify devices and sessions with risk context without treating device identity as person authority**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Platform**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
DeviceIdentity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DeviceIdentityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DeviceIdentityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DeviceIdentityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DeviceIdentityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
DeviceIdentity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```



```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateDeviceIdentity
- ValidateDeviceIdentity
- ApproveDeviceIdentity
- ActivateDeviceIdentity
- SuspendDeviceIdentity
- CorrectDeviceIdentity
- RetireDeviceIdentity

Reference Events:

- DeviceIdentityCreated
- DeviceIdentityValidated
- DeviceIdentityApproved
- DeviceIdentityActivated
- DeviceIdentitySuspended
- DeviceIdentityCorrected
- DeviceIdentityRetired

Reference queries:

- GetDeviceIdentity
- ListDeviceIdentityRecords
- GetDeviceIdentityTimeline
- GetDeviceIdentityEvidence
- GetDeviceIdentityDecisionPackage
- GetDeviceIdentityExceptions
- GetDeviceIdentityAuditTrail

Reference API surface:

```

POST /api/v1/deviceidentity/commands
GET  /api/v1/deviceidentity/{id}
GET  /api/v1/deviceidentity/{id}/timeline
GET  /api/v1/deviceidentity/{id}/evidence
GET  /api/v1/deviceidentity/{id}/decisions
POST /api/v1/deviceidentity/{id}/exceptions
POST /api/v1/deviceidentity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
deviceidentity_aggregate	authoritative subject
deviceidentity_version	immutable submitted, approved, issued, or signed versions
deviceidentity_relationship	governed relationships
deviceidentity_decision	binding Decisions and rationale
deviceidentity_evidence_link	provenance and evidence relationships
deviceidentity_event_outbox	transactional Event publication
deviceidentity_idempotency	duplicate-write protection
deviceidentity_exception	exception, claim, dispute, or hold
deviceidentity_correction	correction and supersession lineage
deviceidentity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

AI Agent and Agent-Run Identity

Metadata	Value
Volume	5
Chapter ID	V05-05
Subject	AIAgentIdentity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	AI Orchestrator / Security
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **identify AI Agents, runs, models, Tools, represented principals, approvals, and accountable owners**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **AI Orchestrator / Security**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AIAgentIdentity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AIAgentIdentityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AIAgentIdentityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AIAgentIdentityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AIAgentIdentityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AIAgentIdentity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAIAgentIdentity
- ValidateAIAgentIdentity
- ApproveAIAgentIdentity
- ActivateAIAgentIdentity
- SuspendAIAgentIdentity
- CorrectAIAgentIdentity
- RetireAIAgentIdentity

Reference Events:

- AIAgentIdentityCreated
- AIAgentIdentityValidated
- AIAgentIdentityApproved
- AIAgentIdentityActivated
- AIAgentIdentitySuspended
- AIAgentIdentityCorrected
- AIAgentIdentityRetired

Reference queries:

- GetAIAgentIdentity
- ListAIAgentIdentityRecords
- GetAIAgentIdentityTimeline
- GetAIAgentIdentityEvidence
- GetAIAgentIdentityDecisionPackage
- GetAIAgentIdentityExceptions
- GetAIAgentIdentityAuditTrail

Reference API surface:

```

POST /api/v1/aiagentidentity/commands
GET  /api/v1/aiagentidentity/{id}
GET  /api/v1/aiagentidentity/{id}/timeline
GET  /api/v1/aiagentidentity/{id}/evidence
GET  /api/v1/aiagentidentity/{id}/decisions
POST /api/v1/aiagentidentity/{id}/exceptions
POST /api/v1/aiagentidentity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```



```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
aiagentidentity_aggregate	authoritative subject
aiagentidentity_version	immutable submitted, approved, issued, or signed versions
aiagentidentity_relationship	governed relationships
aiagentidentity_decision	binding Decisions and rationale
aiagentidentity_evidence_link	provenance and evidence relationships
aiagentidentity_event_outbox	transactional Event publication
aiagentidentity_idempotency	duplicate-write protection
aiagentidentity_exception	exception, claim, dispute, or hold
aiagentidentity_correction	correction and supersession lineage
aiagentidentity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Account, Credential, and Recovery Lifecycle

Metadata	Value
Volume	5
Chapter ID	V05-06
Subject	CredentialLifecycle
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Auth Service
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **govern account creation, verification, password, passkey, federation, recovery, lockout, revocation, and compromise**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Auth Service**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
CredentialLifecycle	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CredentialLifecycleVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CredentialLifecycleDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CredentialLifecycleEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CredentialLifecycleException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
CredentialLifecycle {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateCredentialLifecycle
- ValidateCredentialLifecycle
- ApproveCredentialLifecycle
- ActivateCredentialLifecycle
- SuspendCredentialLifecycle
- CorrectCredentialLifecycle
- RetireCredentialLifecycle

Reference Events:

- CredentialLifecycleCreated
- CredentialLifecycleValidated
- CredentialLifecycleApproved
- CredentialLifecycleActivated
- CredentialLifecycleSuspended
- CredentialLifecycleCorrected
- CredentialLifecycleRetired

Reference queries:

- GetCredentialLifecycle
- ListCredentialLifecycleRecords
- GetCredentialLifecycleTimeline
- GetCredentialLifecycleEvidence
- GetCredentialLifecycleDecisionPackage
- GetCredentialLifecycleExceptions
- GetCredentialLifecycleAuditTrail

Reference API surface:

```

POST /api/v1/credentiallifecycle/commands
GET  /api/v1/credentiallifecycle/{id}
GET  /api/v1/credentiallifecycle/{id}/timeline
GET  /api/v1/credentiallifecycle/{id}/evidence
GET  /api/v1/credentiallifecycle/{id}/decisions
POST /api/v1/credentiallifecycle/{id}/exceptions
POST /api/v1/credentiallifecycle/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
credentiallifecycle_aggregate	authoritative subject
credentiallifecycle_version	immutable submitted, approved, issued, or signed versions
credentiallifecycle_relationship	governed relationships
credentiallifecycle_decision	binding Decisions and rationale
credentiallifecycle_evidence_link	provenance and evidence relationships
credentiallifecycle_event_outbox	transactional Event publication
credentiallifecycle_idempotency	duplicate-write protection
credentiallifecycle_exception	exception, claim, dispute, or hold
credentiallifecycle_correction	correction and supersession lineage
credentiallifecycle_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Authentication, OAuth2, OIDC, JWT, and Keycloak

Metadata	Value
Volume	5
Chapter ID	V05-07
Subject	AuthenticationProtocol
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Auth / Security
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define token issuance, claims, audiences, scopes, session binding, rotation, logout, revocation, and Keycloak integration**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Auth / Security**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AuthenticationProtocol	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationProtocolVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationProtocolDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationProtocolEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationProtocolException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AuthenticationProtocol {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAuthenticationProtocol
- ValidateAuthenticationProtocol
- ApproveAuthenticationProtocol
- ActivateAuthenticationProtocol
- SuspendAuthenticationProtocol
- CorrectAuthenticationProtocol
- RetireAuthenticationProtocol

Reference Events:

- AuthenticationProtocolCreated
- AuthenticationProtocolValidated
- AuthenticationProtocolApproved
- AuthenticationProtocolActivated
- AuthenticationProtocolSuspended
- AuthenticationProtocolCorrected
- AuthenticationProtocolRetired

Reference queries:

- GetAuthenticationProtocol
- ListAuthenticationProtocolRecords
- GetAuthenticationProtocolTimeline
- GetAuthenticationProtocolEvidence
- GetAuthenticationProtocolDecisionPackage
- GetAuthenticationProtocolExceptions
- GetAuthenticationProtocolAuditTrail

Reference API surface:

```

POST /api/v1/authenticationprotocol/commands
GET  /api/v1/authenticationprotocol/{id}
GET  /api/v1/authenticationprotocol/{id}/timeline
GET  /api/v1/authenticationprotocol/{id}/evidence
GET  /api/v1/authenticationprotocol/{id}/decisions
POST /api/v1/authenticationprotocol/{id}/exceptions
POST /api/v1/authenticationprotocol/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
authenticationprotocol_aggregate	authoritative subject
authenticationprotocol_version	immutable submitted, approved, issued, or signed versions
authenticationprotocol_relationship	governed relationships
authenticationprotocol_decision	binding Decisions and rationale
authenticationprotocol_evidence_link	provenance and evidence relationships
authenticationprotocol_event_outbox	transactional Event publication
authenticationprotocol_idempotency	duplicate-write protection
authenticationprotocol_exception	exception, claim, dispute, or hold
authenticationprotocol_correction	correction and supersession lineage
authenticationprotocol_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Multi-Factor and Step-Up Authentication

Metadata	Value
Volume	5
Chapter ID	V05-08
Subject	MFAControl
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Domain
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **apply MFA and step-up based on action risk, financial threshold, legal effect, device, and anomaly signals**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Domain**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
MFAControl	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MFAControlVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MFAControlDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MFAControlEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MFAControlException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
MFAControl {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateMFAControl
- ValidateMFAControl
- ApproveMFAControl
- ActivateMFAControl
- SuspendMFAControl
- CorrectMFAControl
- RetireMFAControl

Reference Events:

- MFAControlCreated
- MFAControlValidated
- MFAControlApproved
- MFAControlActivated
- MFAControlSuspended
- MFAControlCorrected
- MFAControlRetired

Reference queries:

- GetMFAControl
- ListMFAControlRecords
- GetMFAControlTimeline
- GetMFAControlEvidence
- GetMFAControlDecisionPackage
- GetMFAControlExceptions
- GetMFAControlAuditTrail

Reference API surface:

```

POST /api/v1/mfacontrol/commands
GET  /api/v1/mfacontrol/{id}
GET  /api/v1/mfacontrol/{id}/timeline
GET  /api/v1/mfacontrol/{id}/evidence
GET  /api/v1/mfacontrol/{id}/decisions
POST /api/v1/mfacontrol/{id}/exceptions
POST /api/v1/mfacontrol/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
mfacontrol_aggregate	authoritative subject
mfacontrol_version	immutable submitted, approved, issued, or signed versions
mfacontrol_relationship	governed relationships
mfacontrol_decision	binding Decisions and rationale
mfacontrol_evidence_link	provenance and evidence relationships
mfacontrol_event_outbox	transactional Event publication
mfacontrol_idempotency	duplicate-write protection
mfacontrol_exception	exception, claim, dispute, or hold
mfacontrol_correction	correction and supersession lineage
mfacontrol_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Session, Refresh, Revocation, and Logout

Metadata	Value
Volume	5
Chapter ID	V05-09
Subject	SessionLifecycle
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Auth Service
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **govern interactive and machine session creation, refresh, idle and absolute timeout, logout, revocation, and device visibility**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Auth Service**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
SessionLifecycle	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SessionLifecycleVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SessionLifecycleDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SessionLifecycleEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SessionLifecycleException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
SessionLifecycle {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateSessionLifecycle
- ValidateSessionLifecycle
- ApproveSessionLifecycle
- ActivateSessionLifecycle
- SuspendSessionLifecycle
- CorrectSessionLifecycle
- RetireSessionLifecycle

Reference Events:

- SessionLifecycleCreated
- SessionLifecycleValidated
- SessionLifecycleApproved
- SessionLifecycleActivated
- SessionLifecycleSuspended
- SessionLifecycleCorrected
- SessionLifecycleRetired

Reference queries:

- GetSessionLifecycle
- ListSessionLifecycleRecords
- GetSessionLifecycleTimeline
- GetSessionLifecycleEvidence
- GetSessionLifecycleDecisionPackage
- GetSessionLifecycleExceptions
- GetSessionLifecycleAuditTrail

Reference API surface:

```

POST /api/v1/sessionlifecycle/commands
GET  /api/v1/sessionlifecycle/{id}
GET  /api/v1/sessionlifecycle/{id}/timeline
GET  /api/v1/sessionlifecycle/{id}/evidence
GET  /api/v1/sessionlifecycle/{id}/decisions
POST /api/v1/sessionlifecycle/{id}/exceptions
POST /api/v1/sessionlifecycle/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C[Policy and evidence gates pass?]
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
sessionlifecycle_aggregate	authoritative subject
sessionlifecycle_version	immutable submitted, approved, issued, or signed versions
sessionlifecycle_relationship	governed relationships
sessionlifecycle_decision	binding Decisions and rationale
sessionlifecycle_evidence_link	provenance and evidence relationships
sessionlifecycle_event_outbox	transactional Event publication
sessionlifecycle_idempotency	duplicate-write protection
sessionlifecycle_exception	exception, claim, dispute, or hold
sessionlifecycle_correction	correction and supersession lineage
sessionlifecycle_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Tenant, Company, Workspace, Facility, and Channel Scope

Metadata	Value
Volume	5
Chapter ID	V05-10
Subject	TenantScope
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity / Platform
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **separate tenant, legal entity, company, workspace, facility, warehouse, channel, project, and jurisdiction context**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity / Platform**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
TenantScope	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantScopeVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantScopeDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantScopeEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantScopeException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
TenantScope {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateTenantScope
- ValidateTenantScope
- ApproveTenantScope
- ActivateTenantScope
- SuspendTenantScope
- CorrectTenantScope
- RetireTenantScope

Reference Events:

- TenantScopeCreated
- TenantScopeValidated
- TenantScopeApproved
- TenantScopeActivated
- TenantScopeSuspended
- TenantScopeCorrected
- TenantScopeRetired

Reference queries:

- GetTenantScope
- ListTenantScopeRecords
- GetTenantScopeTimeline
- GetTenantScopeEvidence
- GetTenantScopeDecisionPackage
- GetTenantScopeExceptions
- GetTenantScopeAuditTrail

Reference API surface:

```

POST /api/v1/tenantscope/commands
GET  /api/v1/tenantscope/{id}
GET  /api/v1/tenantscope/{id}/timeline
GET  /api/v1/tenantscope/{id}/evidence
GET  /api/v1/tenantscope/{id}/decisions
POST /api/v1/tenantscope/{id}/exceptions
POST /api/v1/tenantscope/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
tenantscope_aggregate	authoritative subject
tenantscope_version	immutable submitted, approved, issued, or signed versions
tenantscope_relationship	governed relationships
tenantscope_decision	binding Decisions and rationale
tenantscope_evidence_link	provenance and evidence relationships
tenantscope_event_outbox	transactional Event publication
tenantscope_idempotency	duplicate-write protection
tenantscope_exception	exception, claim, dispute, or hold
tenantscope_correction	correction and supersession lineage
tenantscope_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Membership, Employment, and Participant Relationships

Metadata	Value
Volume	5
Chapter ID	V05-11
Subject	MembershipRelationship
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity / Employee / Customer
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **model employment, membership, supplier, provider, broker, carrier, customer, and operator relationships as independent facts.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity / Employee / Customer**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
MembershipRelationship	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MembershipRelationshipVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MembershipRelationshipDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MembershipRelationshipEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MembershipRelationshipException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
MembershipRelationship {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateMembershipRelationship
- ValidateMembershipRelationship
- ApproveMembershipRelationship
- ActivateMembershipRelationship
- SuspendMembershipRelationship
- CorrectMembershipRelationship
- RetireMembershipRelationship

Reference Events:

- MembershipRelationshipCreated
- MembershipRelationshipValidated
- MembershipRelationshipApproved
- MembershipRelationshipActivated
- MembershipRelationshipSuspended
- MembershipRelationshipCorrected
- MembershipRelationshipRetired

Reference queries:

- GetMembershipRelationship
- ListMembershipRelationshipRecords
- GetMembershipRelationshipTimeline
- GetMembershipRelationshipEvidence
- GetMembershipRelationshipDecisionPackage
- GetMembershipRelationshipExceptions
- GetMembershipRelationshipAuditTrail

Reference API surface:

```

POST /api/v1/membershiprelationship/commands
GET  /api/v1/membershiprelationship/{id}
GET  /api/v1/membershiprelationship/{id}/timeline
GET  /api/v1/membershiprelationship/{id}/evidence
GET  /api/v1/membershiprelationship/{id}/decisions
POST /api/v1/membershiprelationship/{id}/exceptions
POST /api/v1/membershiprelationship/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
membershiprelationship_aggregate	authoritative subject
membershiprelationship_version	immutable submitted, approved, issued, or signed versions
membershiprelationship_relationship	governed relationships
membershiprelationship_decision	binding Decisions and rationale
membershiprelationship_evidence_link	provenance and evidence relationships
membershiprelationship_event_outbox	transactional Event publication
membershiprelationship_idempotency	duplicate-write protection
membershiprelationship_exception	exception, claim, dispute, or hold
membershiprelationship_correction	correction and supersession lineage
membershiprelationship_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Role, Permission, ABAC, and ReBAC

Metadata	Value
Volume	5
Chapter ID	V05-12
Subject	AuthorizationModel
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Domain
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **derive action eligibility from role, relationship, attributes, resource state, mandate, Policy, tenant, and jurisdiction.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Domain**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;

- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AuthorizationModel	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationModelVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationModelDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationModelEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationModelException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AuthorizationModel {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
    sourceVersionRefs[]
    knowledgeCutoff
    evidenceSetRef
}
```



```

policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAuthorizationModel
- ValidateAuthorizationModel
- ApproveAuthorizationModel
- ActivateAuthorizationModel
- SuspendAuthorizationModel
- CorrectAuthorizationModel
- RetireAuthorizationModel

Reference Events:

- AuthorizationModelCreated
- AuthorizationModelValidated
- AuthorizationModelApproved
- AuthorizationModelActivated
- AuthorizationModelSuspended
- AuthorizationModelCorrected
- AuthorizationModelRetired

Reference queries:

- GetAuthorizationModel
- ListAuthorizationModelRecords
- GetAuthorizationModelTimeline
- GetAuthorizationModelEvidence
- GetAuthorizationModelDecisionPackage
- GetAuthorizationModelExceptions
- GetAuthorizationModelAuditTrail

Reference API surface:

```

POST /api/v1/authorizationmodel/commands
GET  /api/v1/authorizationmodel/{id}
GET  /api/v1/authorizationmodel/{id}/timeline
GET  /api/v1/authorizationmodel/{id}/evidence
GET  /api/v1/authorizationmodel/{id}/decisions
POST /api/v1/authorizationmodel/{id}/exceptions
POST /api/v1/authorizationmodel/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]

```

```

G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
authorizationmodel_aggregate	authoritative subject
authorizationmodel_version	immutable submitted, approved, issued, or signed versions
authorizationmodel_relationship	governed relationships
authorizationmodel_decision	binding Decisions and rationale
authorizationmodel_evidence_link	provenance and evidence relationships
authorizationmodel_event_outbox	transactional Event publication
authorizationmodel_idempotency	duplicate-write protection
authorizationmodel_exception	exception, claim, dispute, or hold
authorizationmodel_correction	correction and supersession lineage
authorizationmodel_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW

Area	Classification
behavior proven in another repository-grounded chapter contradictory ownership or path claims	retain that chapter's evidence and classification CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Delegation, Mandate, Power of Attorney, and Representation

Metadata	Value
Volume	5
Chapter ID	V05-13
Subject	DelegationMandate
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security / Contract
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **record who may represent whom, for which actions, limits, time, jurisdiction, revocation, and evidence.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security / Contract**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
DelegationMandate	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationMandateVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationMandateDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationMandateEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationMandateException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
DelegationMandate {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateDelegationMandate
- ValidateDelegationMandate
- ApproveDelegationMandate
- ActivateDelegationMandate
- SuspendDelegationMandate
- CorrectDelegationMandate
- RetireDelegationMandate

Reference Events:

- DelegationMandateCreated
- DelegationMandateValidated
- DelegationMandateApproved
- DelegationMandateActivated
- DelegationMandateSuspended
- DelegationMandateCorrected
- DelegationMandateRetired

Reference queries:

- GetDelegationMandate
- ListDelegationMandateRecords
- GetDelegationMandateTimeline
- GetDelegationMandateEvidence
- GetDelegationMandateDecisionPackage
- GetDelegationMandateExceptions
- GetDelegationMandateAuditTrail

Reference API surface:

```

POST /api/v1/delegationmandate/commands
GET  /api/v1/delegationmandate/{id}
GET  /api/v1/delegationmandate/{id}/timeline
GET  /api/v1/delegationmandate/{id}/evidence
GET  /api/v1/delegationmandate/{id}/decisions
POST /api/v1/delegationmandate/{id}/exceptions
POST /api/v1/delegationmandate/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```



```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
delegationmandate_aggregate	authoritative subject
delegationmandate_version	immutable submitted, approved, issued, or signed versions
delegationmandate_relationship	governed relationships
delegationmandate_decision	binding Decisions and rationale
delegationmandate_evidence_link	provenance and evidence relationships
delegationmandate_event_outbox	transactional Event publication
delegationmandate_idempotency	duplicate-write protection
delegationmandate_exception	exception, claim, dispute, or hold
delegationmandate_correction	correction and supersession lineage
delegationmandate_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Impersonation, Support Access, and Emergency Access

Metadata	Value
Volume	5
Chapter ID	V05-14
Subject	PrivilegedAccess
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Operations
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **govern support impersonation, break-glass access, reason, approval, scope, notification, review, and revocation.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Operations**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
PrivilegedAccess	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivilegedAccessVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivilegedAccessDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivilegedAccessEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivilegedAccessException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
PrivilegedAccess {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreatePrivilegedAccess
- ValidatePrivilegedAccess
- ApprovePrivilegedAccess
- ActivatePrivilegedAccess
- SuspendPrivilegedAccess
- CorrectPrivilegedAccess
- RetirePrivilegedAccess

Reference Events:

- PrivilegedAccessCreated
- PrivilegedAccessValidated
- PrivilegedAccessApproved
- PrivilegedAccessActivated
- PrivilegedAccessSuspended
- PrivilegedAccessCorrected
- PrivilegedAccessRetired

Reference queries:

- GetPrivilegedAccess
- ListPrivilegedAccessRecords
- GetPrivilegedAccessTimeline
- GetPrivilegedAccessEvidence
- GetPrivilegedAccessDecisionPackage
- GetPrivilegedAccessExceptions
- GetPrivilegedAccessAuditTrail

Reference API surface:

```

POST /api/v1/privilegedaccess/commands
GET  /api/v1/privilegedaccess/{id}
GET  /api/v1/privilegedaccess/{id}/timeline
GET  /api/v1/privilegedaccess/{id}/evidence
GET  /api/v1/privilegedaccess/{id}/decisions
POST /api/v1/privilegedaccess/{id}/exceptions
POST /api/v1/privilegedaccess/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
privilegedaccess_aggregate	authoritative subject
privilegedaccess_version	immutable submitted, approved, issued, or signed versions
privilegedaccess_relationship	governed relationships
privilegedaccess_decision	binding Decisions and rationale
privilegedaccess_evidence_link	provenance and evidence relationships
privilegedaccess_event_outbox	transactional Event publication
privilegedaccess_idempotency	duplicate-write protection
privilegedaccess_exception	exception, claim, dispute, or hold
privilegedaccess_correction	correction and supersession lineage
privilegedaccess_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Identity Proofing, KYB, KYC, and Qualification

Metadata	Value
Volume	5
Chapter ID	V05-15
Subject	IdentityProofing
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Compliance / Identity
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **separate asserted identity, verified identity, business verification, sanctions checks, and scoped qualification**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Compliance / Identity**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IdentityProofing	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityProofingVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityProofingDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityProofingEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityProofingException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IdentityProofing {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIdentityProofing
- ValidateIdentityProofing
- ApproveIdentityProofing
- ActivateIdentityProofing
- SuspendIdentityProofing
- CorrectIdentityProofing
- RetireIdentityProofing

Reference Events:

- IdentityProofingCreated
- IdentityProofingValidated
- IdentityProofingApproved
- IdentityProofingActivated
- IdentityProofingSuspended
- IdentityProofingCorrected
- IdentityProofingRetired

Reference queries:

- GetIdentityProofing
- ListIdentityProofingRecords
- GetIdentityProofingTimeline
- GetIdentityProofingEvidence
- GetIdentityProofingDecisionPackage
- GetIdentityProofingExceptions
- GetIdentityProofingAuditTrail

Reference API surface:

```

POST /api/v1/identityproofing/commands
GET  /api/v1/identityproofing/{id}
GET  /api/v1/identityproofing/{id}/timeline
GET  /api/v1/identityproofing/{id}/evidence
GET  /api/v1/identityproofing/{id}/decisions
POST /api/v1/identityproofing/{id}/exceptions
POST /api/v1/identityproofing/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
identityproofing_aggregate	authoritative subject
identityproofing_version	immutable submitted, approved, issued, or signed versions
identityproofing_relationship	governed relationships
identityproofing_decision	binding Decisions and rationale
identityproofing_evidence_link	provenance and evidence relationships
identityproofing_event_outbox	transactional Event publication
identityproofing_idempotency	duplicate-write protection
identityproofing_exception	exception, claim, dispute, or hold
identityproofing_correction	correction and supersession lineage
identityproofing_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Consent, Purpose, Privacy, and Data Subject Rights

Metadata	Value
Volume	5
Chapter ID	V05-16
Subject	ConsentPrivacy
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **record consent, purpose, legal basis, preference, withdrawal, access, correction, deletion limits, and portability**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
ConsentPrivacy	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ConsentPrivacyVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ConsentPrivacyDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ConsentPrivacyEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ConsentPrivacyException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
ConsentPrivacy {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateConsentPrivacy
- ValidateConsentPrivacy
- ApproveConsentPrivacy
- ActivateConsentPrivacy
- SuspendConsentPrivacy
- CorrectConsentPrivacy
- RetireConsentPrivacy

Reference Events:

- ConsentPrivacyCreated
- ConsentPrivacyValidated
- ConsentPrivacyApproved
- ConsentPrivacyActivated
- ConsentPrivacySuspended
- ConsentPrivacyCorrected
- ConsentPrivacyRetired

Reference queries:

- GetConsentPrivacy
- ListConsentPrivacyRecords
- GetConsentPrivacyTimeline
- GetConsentPrivacyEvidence
- GetConsentPrivacyDecisionPackage
- GetConsentPrivacyExceptions
- GetConsentPrivacyAuditTrail

Reference API surface:

```

POST /api/v1/consentprivacy/commands
GET  /api/v1/consentprivacy/{id}
GET  /api/v1/consentprivacy/{id}/timeline
GET  /api/v1/consentprivacy/{id}/evidence
GET  /api/v1/consentprivacy/{id}/decisions
POST /api/v1/consentprivacy/{id}/exceptions
POST /api/v1/consentprivacy/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
consentprivacy_aggregate	authoritative subject
consentprivacy_version	immutable submitted, approved, issued, or signed versions
consentprivacy_relationship	governed relationships
consentprivacy_decision	binding Decisions and rationale
consentprivacy_evidence_link	provenance and evidence relationships
consentprivacy_event_outbox	transactional Event publication
consentprivacy_idempotency	duplicate-write protection
consentprivacy_exception	exception, claim, dispute, or hold
consentprivacy_correction	correction and supersession lineage
consentprivacy_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Cross-Tenant Isolation and Confused-Deputy Prevention

Metadata	Value
Volume	5
Chapter ID	V05-17
Subject	TenantIsolation
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security Architecture
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **prove that humans, services, Portals, Jobs, Events, caches, AI Tools, and operators cannot cross authority boundaries**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security Architecture**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
TenantIsolation	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
TenantIsolation {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateTenantIsolation
- ValidateTenantIsolation
- ApproveTenantIsolation
- ActivateTenantIsolation
- SuspendTenantIsolation
- CorrectTenantIsolation
- RetireTenantIsolation

Reference Events:

- TenantIsolationCreated
- TenantIsolationValidated
- TenantIsolationApproved
- TenantIsolationActivated
- TenantIsolationSuspended
- TenantIsolationCorrected
- TenantIsolationRetired

Reference queries:

- GetTenantIsolation
- ListTenantIsolationRecords
- GetTenantIsolationTimeline
- GetTenantIsolationEvidence
- GetTenantIsolationDecisionPackage
- GetTenantIsolationExceptions
- GetTenantIsolationAuditTrail

Reference API surface:

```

POST /api/v1/tenantisolation/commands
GET  /api/v1/tenantisolation/{id}
GET  /api/v1/tenantisolation/{id}/timeline
GET  /api/v1/tenantisolation/{id}/evidence
GET  /api/v1/tenantisolation/{id}/decisions
POST /api/v1/tenantisolation/{id}/exceptions
POST /api/v1/tenantisolation/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
tenantisolation_aggregate	authoritative subject
tenantisolation_version	immutable submitted, approved, issued, or signed versions
tenantisolation_relationship	governed relationships
tenantisolation_decision	binding Decisions and rationale
tenantisolation_evidence_link	provenance and evidence relationships
tenantisolation_event_outbox	transactional Event publication
tenantisolation_idempotency	duplicate-write protection
tenantisolation_exception	exception, claim, dispute, or hold
tenantisolation_correction	correction and supersession lineage
tenantisolation_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Identity Audit, Non-Repudiation, and Historical Reconstruction

Metadata	Value
Volume	5
Chapter ID	V05-18
Subject	IdentityAudit
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security / Audit
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **reconstruct authentication, token, mandate, permission, session, privileged action, correction, and revocation at a point in time.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

- Reality or external outcome
- ≠ Observation
 - ≠ Claim
 - ≠ derived Perspective
 - ≠ Prediction
 - ≠ Recommendation
 - ≠ authorized Decision
 - ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security / Audit**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IdentityAudit	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityAuditVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityAuditDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityAuditEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityAuditException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IdentityAudit {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIdentityAudit
- ValidateIdentityAudit
- ApproveIdentityAudit
- ActivateIdentityAudit
- SuspendIdentityAudit
- CorrectIdentityAudit
- RetireIdentityAudit

Reference Events:

- IdentityAuditCreated
- IdentityAuditValidated
- IdentityAuditApproved
- IdentityAuditActivated
- IdentityAuditSuspended
- IdentityAuditCorrected
- IdentityAuditRetired

Reference queries:

- GetIdentityAudit
- ListIdentityAuditRecords
- GetIdentityAuditTimeline
- GetIdentityAuditEvidence
- GetIdentityAuditDecisionPackage
- GetIdentityAuditExceptions
- GetIdentityAuditAuditTrail

Reference API surface:

```

POST /api/v1/identityaudit/commands
GET  /api/v1/identityaudit/{id}
GET  /api/v1/identityaudit/{id}/timeline
GET  /api/v1/identityaudit/{id}/evidence
GET  /api/v1/identityaudit/{id}/decisions
POST /api/v1/identityaudit/{id}/exceptions
POST /api/v1/identityaudit/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
identityaudit_aggregate	authoritative subject
identityaudit_version	immutable submitted, approved, issued, or signed versions
identityaudit_relationship	governed relationships
identityaudit_decision	binding Decisions and rationale
identityaudit_evidence_link	provenance and evidence relationships
identityaudit_event_outbox	transactional Event publication
identityaudit_idempotency	duplicate-write protection
identityaudit_exception	exception, claim, dispute, or hold
identityaudit_correction	correction and supersession lineage
identityaudit_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Identity Migration and Legacy Compatibility

Metadata	Value
Volume	5
Chapter ID	V05-19
Subject	IdentityMigration
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Evolution Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **migrate duplicate accounts, legacy tenants, old claims, shared credentials, stale roles, and incompatible identifiers safely**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Evolution Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IdentityMigration	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityMigrationVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityMigrationDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityMigrationEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityMigrationException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IdentityMigration {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIdentityMigration
- ValidateIdentityMigration
- ApproveIdentityMigration
- ActivateIdentityMigration
- SuspendIdentityMigration
- CorrectIdentityMigration
- RetireIdentityMigration

Reference Events:

- IdentityMigrationCreated
- IdentityMigrationValidated
- IdentityMigrationApproved
- IdentityMigrationActivated
- IdentityMigrationSuspended
- IdentityMigrationCorrected
- IdentityMigrationRetired

Reference queries:

- GetIdentityMigration
- ListIdentityMigrationRecords
- GetIdentityMigrationTimeline
- GetIdentityMigrationEvidence
- GetIdentityMigrationDecisionPackage
- GetIdentityMigrationExceptions
- GetIdentityMigrationAuditTrail

Reference API surface:

```

POST /api/v1/identitymigration/commands
GET  /api/v1/identitymigration/{id}
GET  /api/v1/identitymigration/{id}/timeline
GET  /api/v1/identitymigration/{id}/evidence
GET  /api/v1/identitymigration/{id}/decisions
POST /api/v1/identitymigration/{id}/exceptions
POST /api/v1/identitymigration/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
identitymigration_aggregate	authoritative subject
identitymigration_version	immutable submitted, approved, issued, or signed versions
identitymigration_relationship	governed relationships
identitymigration_decision	binding Decisions and rationale
identitymigration_evidence_link	provenance and evidence relationships
identitymigration_event_outbox	transactional Event publication
identitymigration_idempotency	duplicate-write protection
identitymigration_exception	exception, claim, dispute, or hold
identitymigration_correction	correction and supersession lineage
identitymigration_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- cryptographic authentication and secure credential lifecycle
- tenant and represented-principal isolation
- revocation, audit and point-in-time authorization reconstruction
- confused-deputy, impersonation and replay prevention

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Identity and Tenant Conformance Matrix

Metadata	Value
Volume	5
Chapter ID	V05-SYNTH
Subject	IdentityConformanceMatrix
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Identity Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **trace identities, credentials, sessions, relationships, roles, attributes, mandates, tenants, facilities, Policies, audit and tests.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Identity Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IdentityConformanceMatrix	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityConformanceMatrixVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityConformanceMatrixDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityConformanceMatrixEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IdentityConformanceMatrixException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IdentityConformanceMatrix {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```



```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIdentityConformanceMatrix
- ValidateIdentityConformanceMatrix
- ApproveIdentityConformanceMatrix
- ActivateIdentityConformanceMatrix
- SuspendIdentityConformanceMatrix
- CorrectIdentityConformanceMatrix
- RetireIdentityConformanceMatrix

Reference Events:

- IdentityConformanceMatrixCreated
- IdentityConformanceMatrixValidated
- IdentityConformanceMatrixApproved
- IdentityConformanceMatrixActivated
- IdentityConformanceMatrixSuspended
- IdentityConformanceMatrixCorrected
- IdentityConformanceMatrixRetired

Reference queries:

- GetIdentityConformanceMatrix
- ListIdentityConformanceMatrixRecords
- GetIdentityConformanceMatrixTimeline
- GetIdentityConformanceMatrixEvidence
- GetIdentityConformanceMatrixDecisionPackage
- GetIdentityConformanceMatrixExceptions
- GetIdentityConformanceMatrixAuditTrail

Reference API surface:

```

POST /api/v1/identityconformancematrix/commands
GET  /api/v1/identityconformancematrix/{id}
GET  /api/v1/identityconformancematrix/{id}/timeline
GET  /api/v1/identityconformancematrix/{id}/evidence
GET  /api/v1/identityconformancematrix/{id}/decisions
POST /api/v1/identityconformancematrix/{id}/exceptions
POST /api/v1/identityconformancematrix/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
identityconformancematrix_aggregate	authoritative subject
identityconformancematrix_version	immutable submitted, approved, issued, or signed versions
identityconformancematrix_relationship	governed relationships
identityconformancematrix_decision	binding Decisions and rationale
identityconformancematrix_evidence_link	provenance and evidence relationships
identityconformancematrix_event_outbox	transactional Event publication
identityconformancematrix_idempotency	duplicate-write protection
identityconformancematrix_exception	exception, claim, dispute, or hold
identityconformancematrix_correction	correction and supersession lineage
identityconformancematrix_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.